

CORPORATE SOCIAL RESPONSIBILITY AUDIT PROGRAM #18-80-00

The release of this audit program to parties external to IBM requires the written approval of the Chief Auditor.

This program is intended as a guide for assessing risk management in this process through the performance of an audit or a similar engagement. Risk management is the process to identify, manage, and control potential events in order to provide reasonable assurance related to the achievement of IBM's business and control objectives. IBM's control objectives fall into five broad categories:

1. compliance with external laws and regulations, as well as IBM policies and procedures
2. accomplishment of business objectives
3. reliable information for financial reporting and decision making
4. efficient operations, and
5. safeguarding both intellectual and physical assets.

The control assessment questions are intended to address process objectives from the categories above and the risks to achieving those objectives. Objectives and risks in the actual process under review may differ based on organizational, operational, regulatory, and economic factors. As such, individuals performing the engagement must formulate a test strategy based on risks relative to the actual process under review, regardless of whether the risks are identified within this program.

DATE CHANGED	SECTION #	SUBTITLE IN SECTION	CHANGED BY (NAME)	COMMENTS
April 2026	Planning	Process and Objective	Ronnie Juano	Updated the process to Giving and Volunteerism which will cover Matching Gifts and Volunteer Rewards.
		Audit Program Risk Alignment	Ronnie Juano	Removed Separation of Duties (SOD) risk area. Updated the Key Control Question to reflect the renamed section for Giving and Volunteerism.
		Data Analysis	Ronnie Juano	Removed SOD analysis. Updated the Anomalies section to reflect potential risks.
		Reference Material	Ronnie Juano	Included the process-related reference links.
		Self-service Reports	Ronnie Juano	Added as reference to self-serve reports.
	Control Assessment Questions	Contributions - Process and Payment Controls (PC001.P, PC002.P)	Ronnie Juano	Updated the test approaches.
		Contributions - Accounting Controls (AC001.P)	Ronnie Juano	Added a test approach.
		Giving and Volunteerism - Process and Payment Controls (PM001.P)	Ronnie Juano	Renamed the section to Giving and Volunteerism. Added a test approach.
		Giving and Volunteerism - Accounting Controls (AM001.P)	Ronnie Juano	Renamed the section to Giving and Volunteerism.

CORPORATE SOCIAL RESPONSIBILITY

AUDIT PROGRAM #18-80-00

September 2025	Planning; Key Control Questions	Reference Material; Contributions: PC001.P	Shawn Kronenberger	Deleted inactive link (no longer needed); Updated "SalesForce" to "IBM SalesCloud"
May 2025	Planning	Audit Program Risk Alignment	WW Ops	Removed extra wording in Payment Controls and Exception Processing Defined Risk Area table
October 2024	Various	Various	Shawn Kronenberger	Annual review/update provided by CSR Global Controls and Compliance Leader
May 2023	All	All	Shawn Kronenberger	Updated Reference Links and in appropriate places changed matching grants to matching gifts
April 2023	Data Protection	DP001.P	Don Dobrzelewski	Added Privacy Testing
February 2023	All	All	CA&AS	Converted from Notes into a Word document and into a Box folder

CORPORATE SOCIAL RESPONSIBILITY AUDIT PROGRAM #18-80-00

Table of Contents

PROCESS AND OBJECTIVE	4
PLANNING: Data Analysis.....	6
PLANNING: Fraud Template.....	10
PLANNING: Self-Service Reports.....	11
CONTROL ASSESSMENT QUESTIONS	12
Key Control Question: 1. Contributions - Process and Payment Controls.....	12
Primary Test: Payment Controls (PC001.P).....	13
Primary Test: Payment Exceptions (PC002.P).....	16
Primary Test: Procurement Bypass (PC003.P)	17
Key Control Question: 2. Contributions - Accounting Controls	18
Primary Test: Accounting Controls (AC001.P).....	19
Key Control Question: 4. Giving and Volunteerism - Process and Payment Controls	20
Primary Test: Payment Controls (PM001.P)	21
Key Control Question: 5. Giving and Volunteerism - Accounting Controls	22
Primary Test: Accounting Controls (AM001.P)	23
Key Control Question: 6. Data Protection and Privacy	24
Primary Test: Data Protection (DP001.P).....	25

CORPORATE SOCIAL RESPONSIBILITY

AUDIT PROGRAM #18-80-00

PROCESS AND OBJECTIVE

Contributions is the process to develop and implement strategies and programs for IBM contributions of cash, products, assets and services to recipient organizations. Programs address key social issues and encourage employee participation.

The Giving and Volunteerism process provides support for higher education institutions, cultural establishments, environmental organizations, and hospitals by matching contributions from employees with cash. The Giving and Volunteerism process is performed by a Third-Party supplier.

CORPORATE SOCIAL RESPONSIBILITY AUDIT PROGRAM #18-80-00

PLANNING: Audit Program Risk Alignment

Corporate Social Responsibility

Defined Risk Area	Audit Risk Level	Key Control Question	Test Number
Payment Controls and Exception Processing	High	Contributions - Process and Payment Controls Giving and Volunteerism - Process and Payment Controls	PC001.P, PC002.P PM001.P
Disbursement Bypasses	Medium	Contributions - Process and Payment Controls	PC003.P
Program Management/Vendor Management	Medium	Giving and Volunteerism - Process and Payment Controls	PM001.P
Data Privacy	Medium	Data Protection & Privacy	DP001.P
Accounting Controls	Low	Contributions - Accounting Controls Giving and Volunteerism - Accounting Controls	AC001.P AM001.P

CORPORATE SOCIAL RESPONSIBILITY AUDIT PROGRAM #18-80-00

PLANNING: Data Analysis

Data analysis should be a part of every engagement where data is available in databases or data warehouses that can be accessed through query programs. This concept enhances the risk-based auditing approach, makes the audit process more efficient, and increases the productivity of the audit team. When the audit team does not have the skills required to perform these tasks, assistance should be sought from the Technology team.

All data used for analysis must be reconciled to an independent source so that the auditor has confidence that the universe is complete.

The [Data Analysis engagement procedures in the Audit Manual](#) (link internal to CA&AS members only) provide further suggestions.

This table shows what data can be reviewed and analysis techniques.

Data to be Analyzed	Analysis to be Performed	Possible Anomalies	Concern
Grants Payments	Select a judgmental sample of donations distributed during the audit period and verify: - Each donation record was reviewed and approved at IBM Grants tool by CSR Compliance Advisor. - That each organization has a valid tax-exempt status in accordance with IRS Publication 78, or other tax-exempt information, and an Affirmation of Compliance (AOC) exists, DPL check, IBM SalesCloud check exist, Find GOE check. - All required approvals were in place as per Corporate Org. Letter 110. The payment was timely, accurate, valid and no duplicate payments were made.	- Unverified partner organization - Unauthorized or inaccurate payments	Non-adherence to the contributions process could result in increased costs, incorrect payments to government jurisdictions, and damage to IBM image.

CORPORATE SOCIAL RESPONSIBILITY AUDIT PROGRAM #18-80-00

PLANNING: Data Analysis (Continued)

Data to be Analyzed	Analysis to be Performed	Possible Anomalies	Concern
Giving and Volunteerism	Select a judgmental sample of matching gifts processed during the audit period to determine whether: - Denied Parties List (DPL) check is performed by IBM before the invoice form Third Party supplier is received. - Invoice reconciliation is performed by comparing transactions from the report within the platform and invoice transaction file submitted by Third Party - Payments were approved and follow appropriate disbursements processes. "Void after 120 days" checks are executed by Third Party in alignment with the agreed process. - Grants did not exceed the annual limits.	- Unverified partner organization - Financial loss	Not adhering to the matching grants process could result in increased costs, fraudulent activity that could go undetected, incorrect tax payments, and damage to IBM image.
Exceptions	Select a judgmental sample of invoices to verify: - Contributions processed outside IBM Grants platform were appropriately approved and documented. - Duplicate payments did not occur. - Root cause analysis occurred, and corrective action taken.	- Financial loss - Unauthorized grants	Inadequate controls in place to identify, monitor, and resolve exceptions or outliers to the process could result in increased costs, misstatements of funds, and provide an outlet for fraudulent activity.

CORPORATE SOCIAL RESPONSIBILITY AUDIT PROGRAM #18-80-00

PLANNING: Data Analysis (Continued)

Data to be Analyzed	Analysis to be Performed	Possible Anomalies	Concern
Bypasses	Select a judgmental sample of APU and Travel@IBM transactions that occurred during the audit period to verify: • That the transaction did not require procurement involvement and was processed via the appropriate means. • Management had procedures in place to prevent bypasses. • If a bypass did occur, validate that control procedures were implemented in a timely manner to ensure that repeat bypasses would be prevented. • If root cause analysis was performed and corrective action was taken.	- Procurement bypass	Inadequate controls in place to prevent and identify procurement bypasses of contribution payments could lead to incorrect and unapproved distribution of funds, tax implications and fraudulent activity.
Accounting Controls - Reconciliations	Select a judgmental sample of reconciliations. Review for the following: • Documented evidence of account reconciliation and review by management. • Unreconciled variances were tracked, aged, and promptly resolved if necessary.	- Financial inaccuracies or misstatements - Incomplete delivery of committed grant	Reconciliations performed incorrectly or untimely could lead to a misstatement of IBM's financial position.

CORPORATE SOCIAL RESPONSIBILITY AUDIT PROGRAM #18-80-00

PLANNING: Reference Material

Corporate Organization Letters

- 110: Corporate Social Responsibility and Delegation of Authority - Contributions
<https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-organization-letters/col-110>
- 131: Delegation of Authority - Procurement
<https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-organization-letters/col-131>

Corporate Instructions, Finance

- FIN 101: Control of Disbursements
<https://w3.ibm.com/ibm/corporate-documents/fin/fin-101>
- FIN 154: Foreign Corrupt Practices Act: Anti-bribery, Record Keeping, and Internal Control Requirements
<https://w3.ibm.com/ibm/corporate-documents/fin/fin-154>
- FIN 168: Business Amenities and Gifts
<https://w3.ibm.com/ibm/corporate-documents/fin/fin-168-leg-168>
- FIN 182: Management Self-Assessment of Control
<https://w3.ibm.com/ibm/corporate-documents/fin/fin-182>

Data Protection Privacy

- Supplier Security & Privacy Agreement
<https://w3.ibm.com/w3publisher/privacy-and-security-online-terms>
- Privacy at IBM
<https://www.ibm.com/support/pages/ibm-privacy>

Process Links

- IBM Impact Community
<https://w3.ibm.com/w3publisher/ibm-csr>
- CSR Grants Administration & Execution
<https://w3.ibm.com/w3publisher/csr-grants>
- Versaic for IBM Contributions
<https://w3.ibm.com/w3publisher/versaic-for-ibm-contributions>
- IBM SkillsBuild
<https://w3.ibm.com/w3publisher/ibm-skillsbuild>
- IBM Impact Accelerator
<https://w3.ibm.com/w3publisher/ibm-impact-accelerator>
- Giving and Volunteerism
<https://w3.ibm.com/w3publisher/ibm-volunteering-giving>
- Service Center Reporting (Highschool)
<https://students.yourlearning.ibm.com/servicecenter>
- Service Center Reporting (Adult)
<https://skills.yourlearning.ibm.com/servicecenter>

CORPORATE SOCIAL RESPONSIBILITY AUDIT PROGRAM #18-80-00

PLANNING: Fraud Template

Fraud is any intentional act or omission designed to deceive others and resulting in the victim suffering a loss and/or the perpetrator achieving a gain. Fraud can be categorized into fraudulent financial reporting, misappropriation of assets, and improper or unauthorized expenditures.

Description of Fraud Risk	Typical Controls that should Detect the Fraud Risk	Testing Approach
Inappropriate and/or unauthorized contributions	Approvals, reviews of lists of donees, check with IBM policy	• Determine if donations were given to approved institutions and/or individuals. • Determine if donations adhere to the approval and/or delegated approval clip levels. • Determine if donations are being used according to IBM policy.

Note: The probability and impact will vary depending on the organization/business unit that is being audited.

CORPORATE SOCIAL RESPONSIBILITY AUDIT PROGRAM #18-80-00

PLANNING: Self-Service Reports

Some information previously included in the Initial Data Request (IDR) items which continue to be relevant information in audits will now be extracted directly by the audit team. These are as follows:

Information previously in IDR	Instructional Materials to download information and applying for access to the source tool
• Management Self-Assessment (MSA) • Risk Assessments/Acceptances	https://ibm.ent.box.com/file/2192896410903

CORPORATE SOCIAL RESPONSIBILITY

AUDIT PROGRAM #18-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Contributions - Process and Payment Controls

Objective:

Are all contribution processes defined and appropriately documented? Are process exceptions documented and appropriately reviewed by management? Are all payments to donees approved and in compliance with IBM policies and procedures? Are government tax regulations met? Is there any evidence of improper payments, contributions, bribes, or any disbursements or expenditures which could be construed as such? Are reimbursements to IBMers including travel expenses valid as defined by corporate travel guidelines?

Risk/Exposure:

If adequate control is not exercised, recipients may receive unauthorized donations, be over reimbursed, reimbursed for non-business-related expenses, or for inappropriate or improperly approved expenses.

Any payment or transaction which is or could be construed as improper could expose IBM to violation of the Foreign Corrupt Practices Act, or other US or local country regulations. Improper payments may also be an indicator of fraudulent activity.

Excessive or inappropriate gifts may be improper and contrary to both IBM policy and government regulations. IBM could be fined, embarrassed, or officers jailed if such gifts are publicly revealed. Such gifts could also indicate associated fraudulent transactions.

Violation of IBM's policy of not maintaining memberships in politically oriented organizations could result in accusations of political bias and jeopardize our business relationships. Therefore, contributions given to these organizations could put IBM at risk.

Inaccuracies in the underlying data may lead to erroneous disclosures in the company's ESG external reporting. This could impact on the reliability of reported metrics, compromise stakeholder confidence, and expose the organization to regulatory, reputational, and compliance risks.

CORPORATE SOCIAL RESPONSIBILITY

AUDIT PROGRAM #18-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Contributions - Process and Payment Controls

Primary Test: Payment Controls (PC001.P)

Objective:

To determine if there are adequate controls and procedures to ensure payments for contributions are in compliance with IBM's policies and procedures and are authorized by management to prevent the misappropriations of IBM funds and unauthorized payments.

Approach:

Request an overview of the different applications and tools utilized in the process to gain an understanding of their capabilities, functions, and the stored supporting documentation that can be leveraged for sample testing.

1. Conduct a review with management and staff to understand the procedures for all contributions including business unit contributions and all grant types. Understand the role of CHQ Corporate Social Responsibility (CSR), and its interactions with all the CSR initiatives and activities around the world.
2. Understand the different transactions managed through the contribution process, including donations (Charitable Contributions) and program expenses. Program expenses include contracted services from non-profit organizations (Fee-for-Service) and contracted services from for-profit organizations (For Profit Initiatives). CSR is also involved in the approval of sponsorships and memberships related to non-profit organizations and universities. Contributions could be through various grant types, i.e., cash, technology, services, assets, travel expenses, etc.
3. Request a complete listing of all contributions made during the audit period, including business unit donations. Verify that all required documentation from the recipient was reviewed and approved prior to the execution of grant. Select a sample of contributions and review evidence showing that each organization was properly vetted, as demonstrated by the following:
 - a. A valid tax-exempt status (e.g. in accordance with IRS Publication 78, or other tax-exempt information applicable to the local country). Determine if the tax status provided is still valid.
 - b. Affirmation of Compliance (AOC)
 - c. Denied Parties List (DPL) check (this would also apply to students for Fellowship Programs)
 - d. Perform an IBM SalesCloud check to verify whether an existing opportunity with the organization already exists, as this may present a potential conflict of interest.
 - e. IBM Find GOE check
 - f. CSR Due Diligence Form
 - g. Country-specific documentation required
4. Were the approvals as required by Corporate Organization Letter 110 - Corporate Social Responsibility and Delegation of Authority – Contributions were obtained for each grant executed for the organization?
5. Were all other approvals as required by the contribution process obtained, including the approvals from Risk, Compliance, and Integrity (RCI) depending on the country-specific thresholds?
6. Were business unit donations supported by the required business unit executive approvals?
7. Was the grant executed using the standard contract template? If there were changes to the standard contract template, were these supported by Legal review and approval?
 - a. Identify any established processes used to capture grants executed outside of the contributions tool.
 - b. If there were grants executed outside of the contributions tool, select samples to ensure the required vetting checks and approvals were obtained and documented.

CORPORATE SOCIAL RESPONSIBILITY

AUDIT PROGRAM #18-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Contributions - Process and Payment Controls

Primary Test: Payment Controls (PC001.P)

(Continued)

8. Was each cash contribution deposited in a timely manner? Determine if outstanding checks are monitored and appropriate actions are taken. Do explanations and supporting documentation exist for each credit balance.
9. Were the cash contribution made timely and in accordance with the contractual milestones?
 - a. Understand the different milestones that could be incorporated into the contract, i.e. number of learners, progress reports, utilization certificates, etc.
 - b. If the contract includes established milestones, were the milestone achievements supported and reviewed prior to payment?
 - c. For milestones related to the number of learners:
 - i. Understand the various platforms and methods used to capture learner counts for inclusion in IBM's dashboard. Learners may complete the program through IBM's platform by default. Some partner organizations may use their own platforms and transmit completion data to IBM via API, while others may submit learner completions in bulk manually through file uploads.
 - ii. Were the number of learners reported as an achieved milestone by the partner organization supported?
 - iii. For manual bulk uploads, was valid supporting documentation provided in accordance with the established process?
 - iv. Were the required validation procedures and InfoSec checks performed in a timely manner to confirm learner legitimacy (e.g., completion duration, detection of disposable email accounts, offline completion reviews)?
 - v. For partner organizations flagged for review, were investigations conducted and conclusions supported by validated documentation as required under the established Non-Compliance Process?
10. Request a list of all payments and test for duplicate payments. Determine if donee organizations received more than one payment at the same address and at different addresses. Validate for accuracy. Were payments made to the same address, but with different donee organization names? If so, why?
11. Determine the adequacy of controls to prevent unauthorized or unapproved contributions or Gifts from being made. How is the CSR organization made aware of payments that could occur without following the process? For example, were payments processed via employee payable (TRAVEL@IBM) or accounts payable (either the Accounts Payable application linked with Procurement purchase orders or the Accounts Payable Utility application)? Work with the different teams (TRAVEL@IBM/Buy@IBM/Accounts Payable) to obtain a universe of notification of payments sent to the Contribution and Giving and Volunteerism. Validate that the review of the expense was conducted and that there is documentation to support the decision back to Employee Payables to reimburse.

Were the non-cash contributions delivered timely and accurately based on the contractual commitments?
12. Understand the different relevant regulatory requirements related to CSR activities for each country, where applicable (e.g., India, Slovakia, Brazil, etc.).
 - a. Was there an established process to ensure compliance with the local regulatory requirements? Understand the role of the CSR organization and other IBM organization in each of the established processes.
 - b. Was the established process to ensure compliance executed timely and accurately to avoid regulatory exposure?

CORPORATE SOCIAL RESPONSIBILITY

AUDIT PROGRAM #18-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Contributions - Process and Payment Controls

Primary Test: Payment Controls (PC001.P)

(Continued)

13. Determine the various data elements for which the CSR organization is responsible and assess whether their accuracy could impact external ESG reporting.
14. Determine that the line organization has developed a separation of duties assessment, and that a management system exists to review and confirm that conflicts were identified and eliminated.
15. Determine that no individual has responsibility for more than one of the following related activities:
 - a. Selecting the donee and determining amounts of donations.
 - b. Approving submitted donations under IBM Grants tool and approving donation payments.

CORPORATE SOCIAL RESPONSIBILITY

AUDIT PROGRAM #18-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Contributions - Process and Payment Controls

Primary Test: Payment Exceptions (PC002.P)

Objective:

Are all contributions processes defined and appropriately documented? Are process exceptions handled appropriately?

Approach:

Determine if exceptions to the process exist. Request and review management-specific Gifts requests. If exceptions to the process exist, determine the following:

1. Request a listing of all payments made during the audit period. Test to determine if payments were made appropriately and timely.
2. Verify that any payments processed prior to milestone achievement, as well as all other process exceptions, were supported by appropriate documentation and approved in accordance with the established exception process.

CORPORATE SOCIAL RESPONSIBILITY

AUDIT PROGRAM #18-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Contributions - Process and Payment Controls

Primary Test: Procurement Bypass (PC003.P)

Objective:

To determine if controls are in place to prevent the bypass of procurement in selecting suppliers and/or making purchases.

Approach:

Review documentation and management policies to validate the control measures listed below. In selecting a sample, refer to the Global Accounts Payable website.

Transactions could occur via the Contributions and Matching Grants process managed by CHQ Corporate Social Responsibility (CSR). Transactions could also occur, bypassing CHQ CSR's process, with payments made via Accounts Payable Utility (APU), Travel@IBM (Concur) or via the Accounts Payable system if Procurement purchase orders were used.

1. Review APUs, Travel@IBM, Accounts Payable activity etc. from the previous 12 months - associated with relevant commodity codes, or descriptions of payee and purpose.
2. Determine if management had procedures in place to prevent the bypass of procurement. If a bypass did occur, validate that control procedures were implemented in a timely manner to ensure that repeat bypasses would be prevented. If applicable, review any control risk assessment (CRA) measurements that the organization may have in place for procurement bypasses.
3. Obtain a listing of suppliers used in support of the organization for general purchasing and select a sample of suppliers to confirm that they had been approved by procurement and that fair value analysis had been performed.

CORPORATE SOCIAL RESPONSIBILITY

AUDIT PROGRAM #18-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Contributions - Accounting Controls

Objective:

Are all account reconciliations performed monthly with the appropriate level of formal management review and approval? To determine if all contributions are properly confirmed with the recipient in order to satisfy tax requirements.

Risk/Exposure:

Reconciliations performed correctly and on time are the primary control to identify any differences between the general ledger and the systems which feed it. Failure to perform reconciliations consistently indicates a lack of management focus on essential financial controls and could lead to a misstatement of the company's financial position. Failure to receive certification that all contributions have been received could result in IBM's inability to take the appropriate tax deduction of the Gifts.

CORPORATE SOCIAL RESPONSIBILITY

AUDIT PROGRAM #18-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Contributions - Accounting Controls

Primary Test: Accounting Controls (AC001.P)

Objective:

To determine if the recording and reporting of all cash contributions were accurate and appropriate regarding plan authorizations and accounting requirements.

Approach:

1. Review procedures and approval requirements for cash contributions.
2. Review monthly ledger reconciliations for contributions. Verify the following:
 - a. Reconciliations are completed timely.
 - b. Values are fully supported by backup documentation.
 - c. Unreconciled items are appropriately aged and reported.
 - d. Action is taken to close unreconciled items timely.
3. Review the reconciliation at the end of each grant to ensure all deliverables (i.e., cash, technology, services, assets, travel expenses, etc.) were delivered and supported prior to the closure of each grant.
4. Review the yearly tax certification process for contributions excluding Giving and Volunteerism.
 - a. Verify that IBM has sent the required contribution certification form to all recipients of contributions.
 - b. Verify that the required certification forms have been received by IBM from all recipients of contributions.
 - c. For those that were not received, verify that IBM performed sufficient follow-up.

CORPORATE SOCIAL RESPONSIBILITY

AUDIT PROGRAM #18-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Giving and Volunteerism - Process and Payment Controls

Objective:

Are all matching gifts and volunteer rewards program processes defined and appropriately documented? Are process exceptions identified and reviewed by management? Are all payments to donees approved and in compliance with IBM policies and procedures? Are government tax regulations met? Is there any evidence of improper payments, contributions, bribes, or any disbursements or expenditures which could be construed as such? Are reimbursements to IBMers including travel expense valid as defined by corporate travel guidelines?

Risk/Exposure:

If adequate control is not exercised, recipients may receive unauthorized donations, be over reimbursed, reimbursed for non-business-related expenses, or for inappropriate or improperly approved expenses.

Any payment or transaction which is or could be construed as improper could expose IBM to violation of the Foreign Corrupt Practices Act, or other US or local country regulations. Improper payments may also be an indicator of fraudulent activity.

Excessive or inappropriate gifts or recipients may be improper and contrary to both IBM policy and government regulations. IBM could be fined, embarrassed, or officers jailed if such gifts are publicly revealed. Such gifts could also indicate associated fraudulent transactions.

Violation of IBM's policy of not maintaining memberships in politically oriented organizations could result in accusations of political bias and jeopardize our business relationships. Therefore, matching grants paid to these organizations could put IBM at risk.

Inaccuracies in the underlying data may lead to erroneous disclosures in the company's ESG external reporting. This could impact on the reliability of reported metrics, compromise stakeholder confidence, and expose the organization to regulatory, reputational, and compliance risks.

CORPORATE SOCIAL RESPONSIBILITY

AUDIT PROGRAM #18-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Giving and Volunteerism - Process and Payment Controls

Primary Test: Payment Controls (PM001.P)

Objective:

Match gifts and volunteer rewards are performed by a third-party supplier. The objective of the test is to ensure payments for matching grants and volunteer rewards are in compliance with the third-party contract.

Approach:

Third Party conduct reviews are in compliance with the contract. Checks were performed by IBM before the payment to the Third Party.

1. Validate if Denied Party List (DPL) check was performed by IBM before the invoice from Third Party supplier was received.
2. Review that Invoice reconciliation was performed by comparing transactions from the report within the platform and invoice transactions file submitted by Third Party.
3. Confirm that Payments were approve and follow appropriate disbursement processes.
4. Verify that "Void after 120 days" checks were executed by Third Party in alignment with the agreed process.
5. Determine whether volunteer hours were reviewed and any discrepancies appropriately analyzed and investigated and verify that hours and associated rewards were reversed when warranted.

CORPORATE SOCIAL RESPONSIBILITY

AUDIT PROGRAM #18-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Giving and Volunteerism - Accounting Controls

Objective:

Are all reconciliations performed on a monthly basis with the appropriate level of management review and approval? To determine if all matching grants are properly confirmed with the recipient in order to satisfy tax requirements.

Risk/Exposure:

Reconciliations performed correctly and on time are the primary control to identify any differences between the general ledger and the systems which feed it. Failure to perform reconciliations consistently indicates a lack of management focus on essential financial controls and could lead to a misstatement of the company's financial position. Failure to receive certification that all matching grants have been received could result in IBM's inability to take the appropriate tax deduction of the grant.

CORPORATE SOCIAL RESPONSIBILITY

AUDIT PROGRAM #18-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Giving and Volunteerism - Accounting Controls

Primary Test: Accounting Controls (AM001.P)

Objective:

To determine if the recording and reporting of matching grants were accurate and appropriate with regard to plan authorizations and accounting requirements.

Approach:

Review procedures and approval requirements for cash contributions.

1. Validate that processes are established to charge expenses to appropriate accounts.

CORPORATE SOCIAL RESPONSIBILITY

AUDIT PROGRAM #18-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Data Protection and Privacy

Objective:

Is IBM employee data shared with a third party adequately protected? Does a valid data processing agreement exist between IBM and any Third Parties involved in the process?

Risk/Exposure:

Failure to protect PI and SPI could enable fraudulent activity, which could result in dissatisfied employees, damage to employees and to IBM's image and expose IBM to risk of litigation.

CORPORATE SOCIAL RESPONSIBILITY

AUDIT PROGRAM #18-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Data Protection and Privacy

Primary Test: Data Protection (DP001.P)

Objective:

Validate that adequate controls are in place to protect IBM employee PI and SPI

Approach:

1. Identify what PI and SPI data is handled/processed by any third parties involved in the end-to-end process. Identify any regulations relating to data handling, including what types of data can be handled by third parties, or handled by anyone outside the country. Consider ways that PI and SPI could be compromised.
2. Consider the following tests for any individuals involved in the end-to-end process that have access to PI or SPI. This includes IBM employees, contractor employees working for IBM departments, and vendor firms (their employees).
 - Access to data and applications (including granting, periodic revalidating, and revoking)
 - Separation of duties (including assessment of roles, tasks, and access to applications)
 - File transfers among IBM and vendors, including encryption and classification as IBM Confidential where required
 - Spreadsheet protection
 - Disaster recovery / business continuity planning. For example, if work is normally performed at IBM or vendor office facilities, but a disaster occurs and the plan calls for employees to work remotely, how secure are the means employees would have to perform their tasks at a remote location? Would unsecured telephone and internet access be used?
 - Data protection terms in contracts. Review contracts with vendors or contractor employees. How is data privacy assured? How does IBM monitor vendor protection of data? Are IBM's information technology standards in place, monitored, and enforced?

Test: Privacy

Objective:

Privacy laws impose requirements on how IBM and its Clients process Personal Information (PI). The Global Privacy Control Assessment Questions are composed with two key areas of the business to help address compliance with these various high-level laws.

- **IBM as a Controller** – The Enterprise Privacy Baseline – Controller establishes the high-level requirements that IBM must meet when acting as a Controller of Personal Information (PI). That is, PI that IBM collects and processes for its own purposes, such as Business Contact Information that IBM holds on its existing or potential customers or suppliers.
- **IBM as a Processor** – The Enterprise Privacy Baseline – Processor establishes the principles and requirements that IBM must meet when acting as a Processor of Client Personal Information (PI) and applies to all products, offerings, and services (including their components) that IBM provides to Clients, regardless of whether IBM develops or re-brands them, or provides them for a fee or on a beta, trial, or no-charge basis.

CORPORATE SOCIAL RESPONSIBILITY

AUDIT PROGRAM #18-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Data Protection and Privacy

Primary Test: Data Protection (DP001.P)

(Continued)

Approach:

Review the Data Privacy responses provided from the Initial Data Request. Determine if IBM is Controller or Processor of PI/SPI data in the process.

Testing:

IBM as Controller

If IBM is Controller, request a risk-based sample of Global Privacy Assessments for the processes and/or assets.

Complete the testing from the following link: <https://ibm.ent.box.com/file/1198251968388>

IBM as Processor

If IBM is Processor, select a sample of products/offerings/services provided for the in-scope activities.

Complete the testing from the following link: <https://ibm.ent.box.com/file/1198263127550>

IBM as both Controller and Processor

Test either IBM as Controller or Processor, do not test both. Consider the volume and sensitivity of the controller and processor data and select the higher risk.